

A low-angle, upward-looking perspective of several tall skyscrapers. The image is heavily stylized with a red color overlay. The buildings are dark, and the sky is a solid, vibrant red. The perspective creates a sense of height and scale.

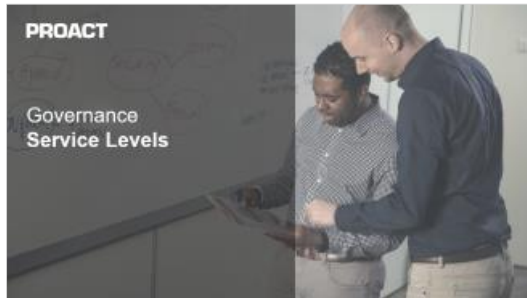
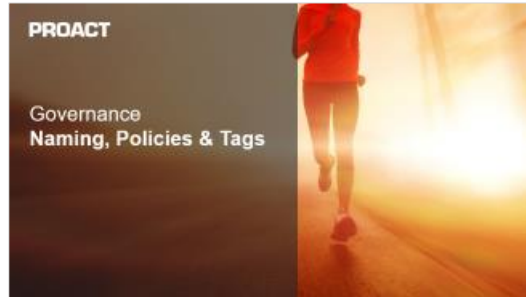
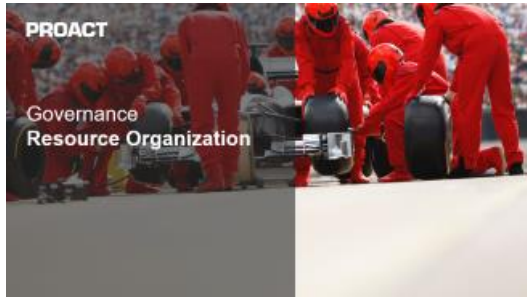
Foundation Workshop
GOVERNANCE

PROACT

Azure Governance Session

PROACT

Agenda



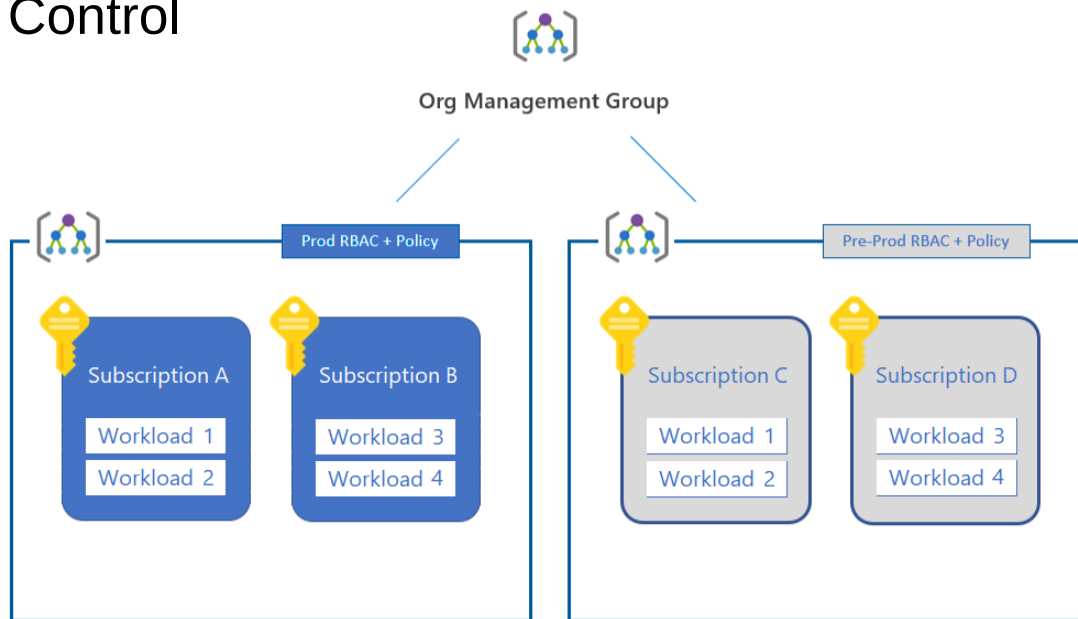
A photograph of a Formula 1 pit stop. A team of crew members, all wearing bright red jumpsuits and helmets, are working on a silver and black race car. They are focused on changing the tires. The scene is set on a racetrack with a blurred crowd in the background. The image is split vertically: the left half is semi-transparent dark grey, and the right half is the original color photo.

PROACT

Governance
Resource Organization

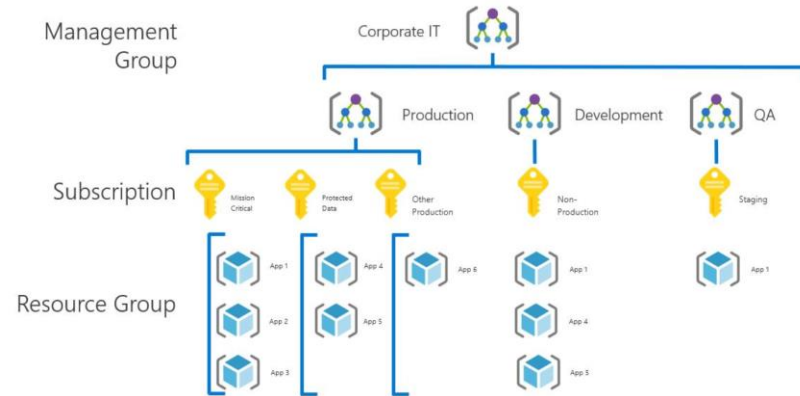
Management Groups

- Azure Policies
- Role Based Access Control

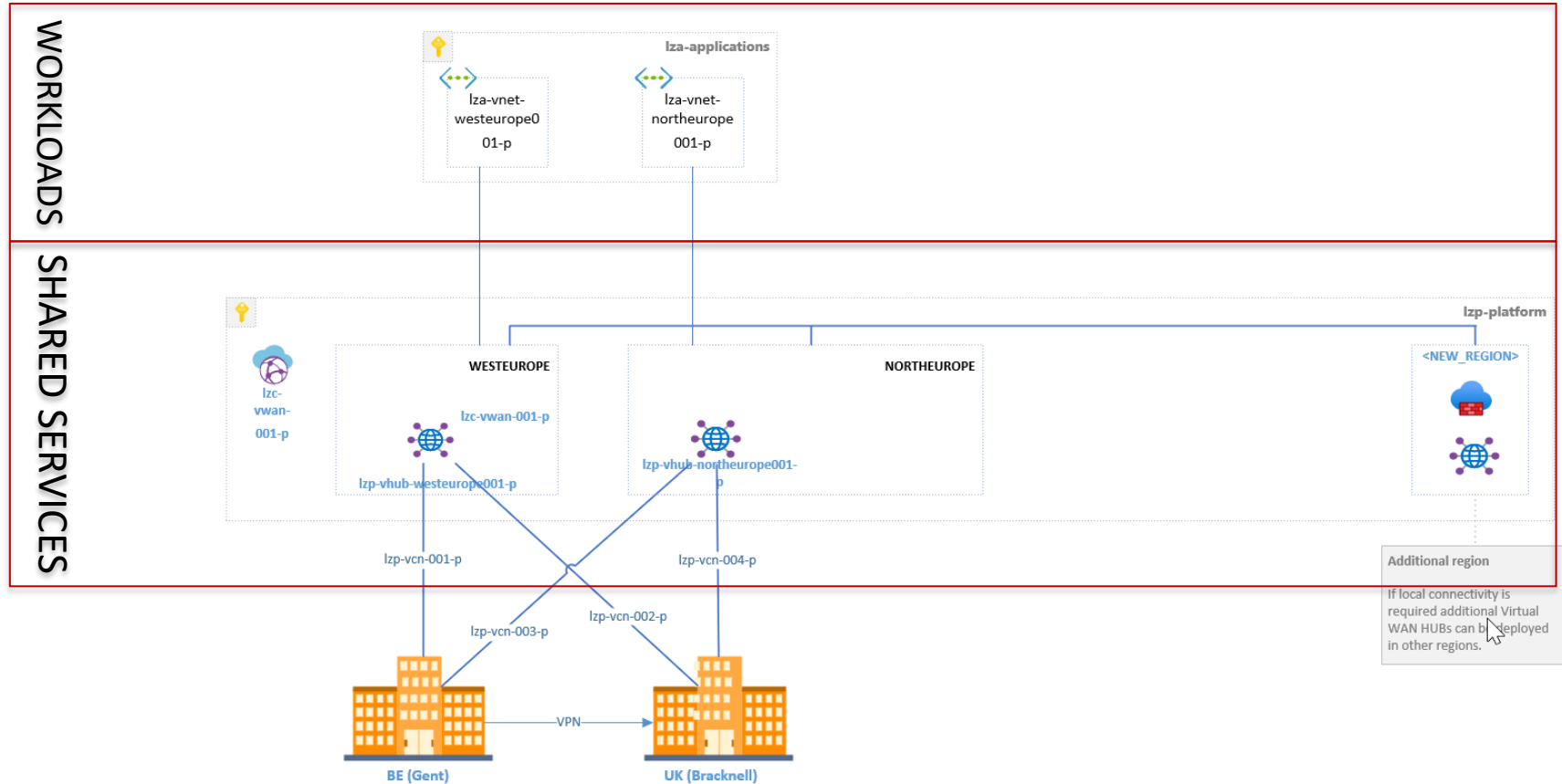


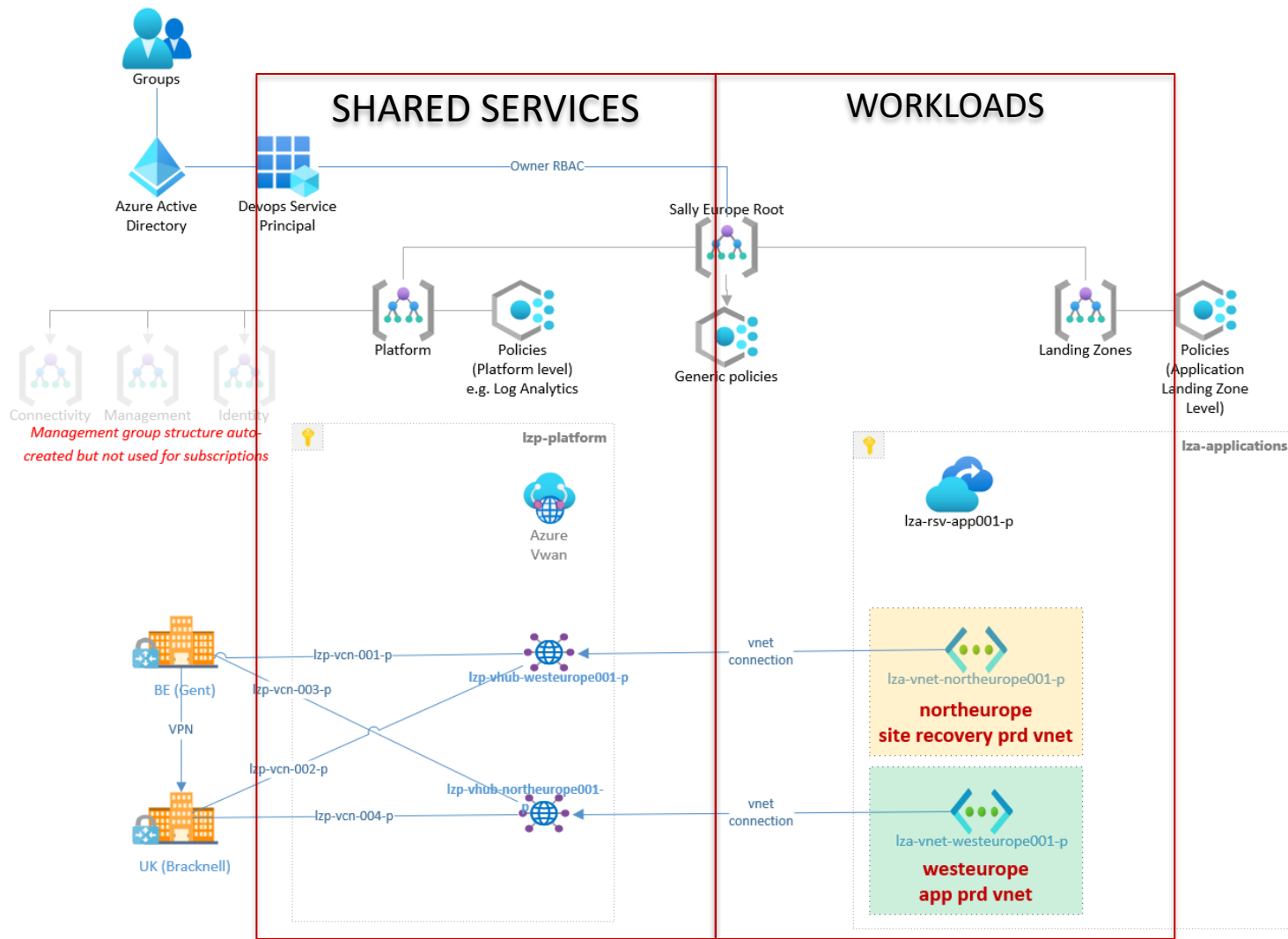
Management Groups

- Workload separation
 - » Preprod, production
- Application category
 - » Website, backoffice
- Functional categories
 - » Finance, Sales, IT, ...
- Business Unit
 - » Insurance, Banking, ..
- Geographic
 - » Continent, Country, etc



Shared services and workloads





Resource organization - Accounts

Enterprise Contract

Department

Account

Subscriptions



Resource organization - Physical

Global Azure Services

Data Residence Boundary (geopolitical region)

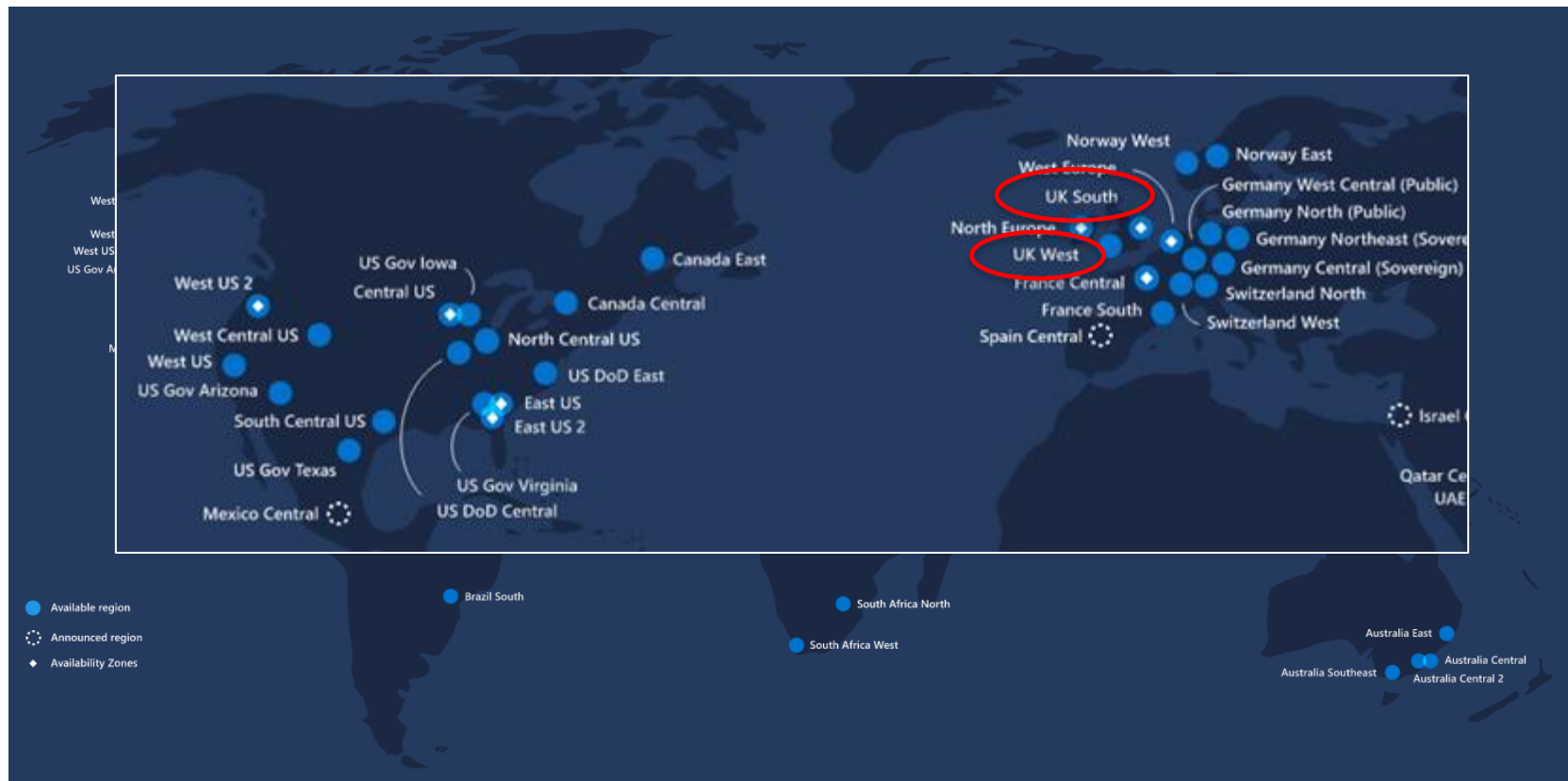
Region

Availability zone / Datacenter

Common resource

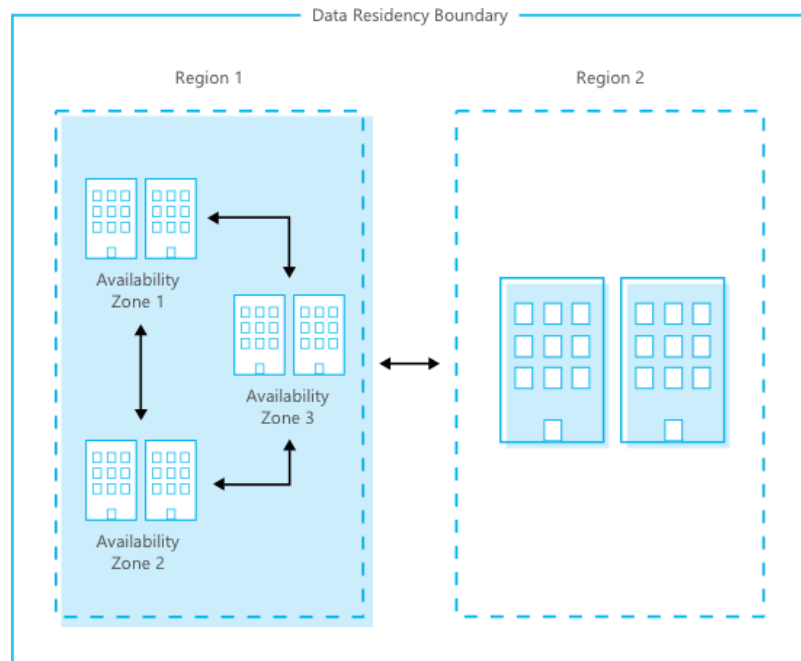


Regions



Region Pairs & Availability Zones

- Data Residency Boundary
 - » Compliance boundaries
 - » All regions have a region pair for geo redundant services in same DRB
- Availability zone
 - » Provides datacenter redundancy within a region



Resource Organization - Logical

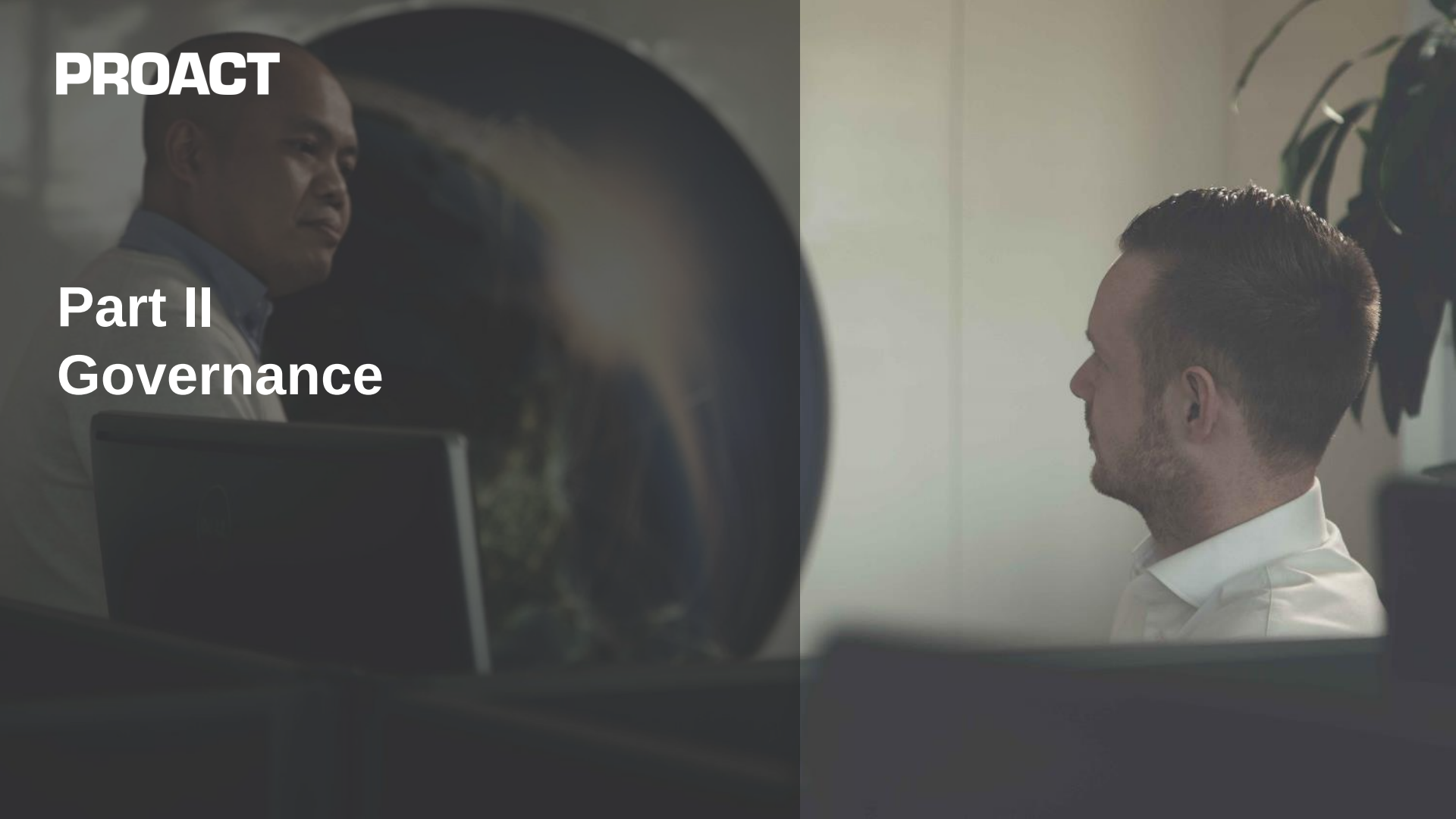
Management Groups

Subscriptions

Resource Groups

Resource





PROACT

Part II
Governance

Role Based Access Control

- Default roles
 - » Reader
 - » Contributor
 - » Owner
- Function based roles
 - » Security Reader
 - » Network Contributor
- Custom Roles

	Role			
	Reader	Resource-specific or custom role	Contributor	Owner
Scope	 Subscription	Observers		Users managing resources
	 Resource group	Admins		
	 Resource	Automated processes		

Policies

- Auditability of resources

- » Resource types
- » Locations
- » Tags
- » Monitoring
- » Public availability
- » Encryption
- » ...

Policy effect	Audit AuditIfNotExists	Modify DeployIfNotExists Append	Deny
 Management Group	Generic Compliance policies	Generic Remediation policies	Generic Compliance policies
 Subscription			
 Resource group	Workload specific policies		

Resource Groups

- Containers for multiple resources that share the same life cycle.
- Aggregates resources into a single manageable unit.
- Every Azure resource must exist in one (and only one) resource group.
- Secure at the resource group (or resource) level - using role-based access control (RBAC).

Microsoft Azure Search resources, services, and docs (G+/)

Home > Resource groups > cn-weu-t-hybrnetw-rg

cn-weu-t-hybrnetw-rg
Resource group

Search (Ctrl+/)

+ Add Edit columns Delete resource group Refresh Move Export to CSV Assign

Subscription (change): Microsoft Azure Sponsorship (12K) Deployments: No deployment

Subscription ID: [REDACTED]

Tags (change): [Click here to add tags](#)

Filter by name... Type == all Location == all Add filter

Showing 1 to 9 of 9 records. ☐ Show hidden types

☐ Name ↑↓	Type ↑↓	Location ↑↓
☐ cn-weu-t-fw-ip	Public IP address	West Europe
☐ cn-weu-t-hybr-vnet	Virtual network	West Europe
☐ cn-weu-t-mgmt-nsg	Network security group	West Europe
☐ cn-weu-t-priv-nsg	Network security group	West Europe
☐ cn-weu-t-pub-nsg	Network security group	West Europe
☐ cn-weu-t-s2s-lng	Local network gateway	West Europe
☐ cn-weu-t-s2s-vng	Virtual network gateway	West Europe
☐ cn-weu-t-vng-con	Connection	West Europe
☐ cn-weu-t-vng-ip	Public IP address	West Europe

PROACT

Governance
Naming, Policies & Tags



Microsoft CAF naming

- Best practices naming guidelines

<https://docs.microsoft.com/en-us/azure/cloud-adoption-framework/ready/azure-best-practices/naming-and-tagging>

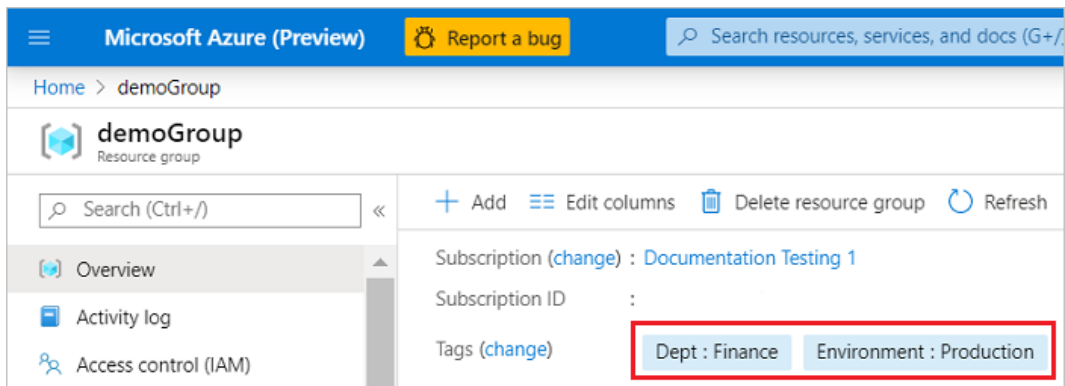
Asset type	Scope	Format	Examples
Subscription	Account/ Enterprise Agreement	<Business Unit>-<Subscription type>-<###>	mktg-prod-001 corp-shared-001 fin-client-001
Resource group	Subscription	rg-<App or service name>-<Subscription type>-<###>	rg-mktgsharepoint-prod-001 rg-network-shared-001 rg-adservices-shared-001
API management service instance	Global	apim-<App or service name>-<###>	apim-navigator-prod-001

Discussion

Do we follow the Microsoft CAF naming convention?

Tags

- Allows metadata on resource groups and resources for filtering and aggregation
 - » Costs
 - » Reporting
 - » Automation



PROACT

Governance Security Baseline



Security Baseline

- Defines guidelines and principles for design
- Based on Enterprise (Security) Architecture guidelines

Azure Security Baseline

■ Confidentiality

- » Ensure appropriate identity, entitlement, and access management for all users e.g. means of defining and assigning correct RBAC roles.
 - › By the use of group assignments where possible
 - › By the use of least privilege principle
- » Access to the management groups & subscriptions will be defined by IT.
 - › No delegation of access control
- » Passwords/secrets/cryptographic keys will be changed on regular basis
 - › By using Secret Management with KeyVault / Vault
- » Minimize tasks for rotation of secrets
 - › Use automatic rotation of certificates and secrets where possible
 - › Use of Microsoft Managed keys for services like Azure storage accounts and SQL Azure Databases
- » Isolate different application environments by the means of network segregation, applying NSGs and controlling access to each other's resources.
 - › Hub and spoke model
 - › Restrict communication between subnets, VMs, and external networks using NSG policies.
- » ...

Azure Security Baseline

■ Integrity

- » Detect and alert on vulnerabilities
 - › By means of enabling Security Center at standard level
- » Protect the integrity of Virtual Machines by configuring right monitoring and alerting mechanism
 - › By means of enabling Azure Monitor
- » Prevent the execution of malware on end-point VMs and resources
 - › By means of introducing appropriate antivirus solutions such as Azure antimalware.
- » All the developments and the changes will be tested in the Pre-production subscriptions and will get approved prior implementation in Production subscriptions.
 - › By using Terraform for the deployment in different stages
- » Prevent compromise and misuse of log data by restricting access to storage accounts where logs are accumulated
 - › By isolating log account in a separate subscription
- » ...

Azure Security Baseline

■ Availability

- » Service availability is aligned with the SLA
 - › Bronze – Single server
 - › Silver – Availability set or multiple zones
 - › Gold – Resources located in multiple regions
- » Ensure all systems can be recovered quickly and correctly, e.g. by means of a business continuity solution based on the defined SLA.
 - › Mission-critical, Critical, Essential
- » Protect web applications against external security attacks by means of web application firewall components with Application Gateway services
- » ...

PROACT

Governance Service Levels



Service Level Objective (and SLA)

Design for	Gold	Silver	Bronze	Dev
Hardware failure	✓	✓	✓	
Zone failure	✓	✓		
Region failure	✓			
Global failure				

Discussion

What design approach matches the required Service Level Objectives?

e.g. Silver is designed against zone failure

Disaster recovery

	Mission-critical	Critical	Essential
Recovery Point Objective	< 5 minutes	<1 hour	< 24 hour
Return To Operations	.. hours	.. hours	.. days

Discussion

What objectives matches the required RTO/RPO?

PROACT

Wrap-up



A low-angle, upward-looking photograph of several tall skyscrapers. The image is heavily stylized with a deep red color overlay. The word "PROACT" is written in large, bold, white, sans-serif capital letters across the center of the image. The perspective creates a sense of height and scale, with the buildings converging towards the top of the frame.

PROACT